

Documentation : Déploiement et Sécurisation d'un Serveur SSH - Nathaniel T

Ce document détaille les étapes nécessaires pour configurer un accès distant sécurisé sur un serveur Linux (basé sur Debian/Ubuntu). Il couvre la gestion des utilisateurs, l'installation d'OpenSSH, sa sécurisation, et la mise en place d'un outil de prévention contre les attaques par force brute (Fail2Ban).

1. Gestion des utilisateurs et des groupes sudo

Travailler directement en tant que `root` est une mauvaise pratique de sécurité. La première étape consiste à créer un utilisateur standard et à lui accorder les privilèges d'administration via `sudo`.

1.1 Création d'un nouvel utilisateur

Pour créer un nouvel utilisateur (remplacez `sysadmin` par le nom souhaité) :

```
adduser sysadmin
```

Le système vous demandera de définir un mot de passe robuste et quelques informations optionnelles.

1.2 Ajout de l'utilisateur au groupe sudo

Pour que ce nouvel utilisateur puisse exécuter des commandes avec des privilèges d'administrateur, ajoutez-le au groupe `sudo` :

```
usermod -aG sudo sysadmin
```

(Note : Sur les systèmes basés sur RHEL/CentOS, le groupe d'administration s'appelle généralement `wheel` au lieu de `sudo`).

Vérification : Connectez-vous avec ce nouvel utilisateur (`su - sysadmin`) et tapez `sudo ls -la /root` pour vérifier que vous avez bien les droits.

2. Mise en place du service SSH

OpenSSH est la norme pour la connexion sécurisée à distance.

2.1 Installation du serveur SSH

Mettez à jour la liste des paquets et installez le serveur SSH :

```
sudo apt update
sudo apt install openssh-server -y
```

2.2 Vérification du service

Assurez-vous que le service est actif et qu'il démarrera automatiquement à chaque redémarrage du serveur :

```
sudo systemctl enable ssh
sudo systemctl start ssh
sudo systemctl status ssh
```

3. Configuration du fichier `sshd_config`

La configuration par défaut de SSH est fonctionnelle, mais elle doit être durcie. Le fichier de configuration principal se trouve ici : `/etc/ssh/sshd_config`.

Ouvrez le fichier avec votre éditeur préféré (ex: `nano` ou `vim`) :

```
sudo nano /etc/ssh/sshd_config
```

3.1 Modification du Port par défaut

Changer le port 22 (par défaut) permet de réduire drastiquement le nombre d'attaques automatisées (bots).

Trouvez la ligne `#Port 22` et modifiez-la :

```
Port 2244 # Choisissez un port libre entre 1024 et 65535
```

3.2 Désactivation de la connexion Root (Root Login)

Pour empêcher un attaquant de se connecter directement avec les droits absolus, désactivez l'accès SSH pour `root`.

Trouvez la ligne `PermitRootLogin` et définissez-la sur `no` :

```
PermitRootLogin no
```

3.3 Authentification par Clé Publique (PubKey)

L'authentification par clé cryptographique est beaucoup plus sûre que les mots de passe. Assurez-vous que ces lignes sont décommentées et configurées sur `yes` :

```
PubkeyAuthentication yes
```

(Recommandation avancée : Une fois que vous avez généré votre paire de clés SSH sur votre machine locale et copié la clé publique sur le serveur avec `ssh-copy-id`, vous pouvez totalement désactiver l'authentification par mot de passe en définissant `PasswordAuthentication no`).

3.4 Application des paramètres

Sauvegardez le fichier et redémarrez le service SSH pour appliquer les modifications :

```
sudo systemctl restart ssh
```

Attention : Ne fermez pas votre session actuelle. Ouvrez un nouveau terminal et testez la connexion avec votre nouvel utilisateur et le nouveau port (`ssh -p 2244 sysadmin@adresse_ip`) pour vous assurer de ne pas vous bloquer en dehors du serveur.

4. Mise en place de Fail2Ban

Fail2Ban analyse les journaux (logs) du serveur et bannit temporairement les adresses IP qui présentent un comportement malveillant, comme des erreurs de mot de passe répétées (brute-force).

4.1 Installation de Fail2Ban

```
sudo apt install fail2ban -y
```

4.2 Configuration de Fail2Ban

Il est déconseillé de modifier le fichier `jail.conf` principal, car il sera écrasé lors des mises à jour. Créez une copie nommée `jail.local` :

```
sudo cp /etc/fail2ban/jail.conf /etc/fail2ban/jail.local
sudo nano /etc/fail2ban/jail.local
```

4.3 Sécurisation de la prison (jail) SSH

Dans le fichier `jail.local`, trouvez la section `[sshd]`. Modifiez ou ajoutez les paramètres suivants pour les adapter à votre configuration (notamment le port modifié) :

```
[sshd]
enabled = true
port    = 2244          # IMPORTANT : Mettez ici le port confi
                        # guré à l'étape 3.1
logpath = %(sshd_log)s
backend = %(sshd_backend)s
maxretry = 3            # Nombre de tentatives avant bannisseme
                        # nt
bantime  = 3600         # Durée du bannissement en secondes (i
                        # ci 1 heure)
findtime = 600          # Fenêtre de temps pour les tentatives
                        # (10 minutes)
```

4.4 Démarrage et Vérification

Activez et démarrez Fail2Ban :

```
sudo systemctl enable fail2ban
sudo systemctl restart fail2ban
```

Pour vérifier le statut de votre prison SSH et voir s'il y a des adresses IP bannies :

```
sudo fail2ban-client status sshd
```

Félicitations, votre serveur dispose désormais d'un accès SSH robuste, protégé contre les connexions `root` directes, utilisant un port non standard et

défendu par un outil anti-bruteforce actif !